

# Information Security Management System (ISMS) Manual

## Document Control

### Version History

| Version    | Document Version | Description                                                      | Document Author |
|------------|------------------|------------------------------------------------------------------|-----------------|
| 2023       |                  | Release                                                          | Lam             |
| Up to 2026 |                  | Updated to Megtech's security & compliance framework<br>document |                 |

### Document Approval

| Signature              | Role                | Approval Date |
|------------------------|---------------------|---------------|
| Information Management | Managing Director / | Approval      |
|                        |                     |               |

### 1. Purpose

This document specifies the framework of the Information Security Management System (ISMS) for Megtech. It defines the requirements and controls necessary to implement and maintain compliance with the ISO/IEC 27001 standard.

### 2. Company Background

To address ongoing cybersecurity obligations, safeguard customer information, and enhance operational resilience, Megtech operates an Information Security Management System aligned with the ISO/IEC 27001 standard across its cloud infrastructure and digital service offerings.

### 3. Intended Outcome and Scope of the ISMS

#### 3.1 Intended Outcome

The intended outcome of the Megtech ISMS is to deliver resilient, secure digital platforms and technology solutions to clients, safeguarding all proprietary information and end-user data processed within Megtech systems.

### 3.2 Scope and Boundary

- **Scope:** The Information Security Management System covers the design, development, deployment, maintenance, and operation of Megtech digital solutions and cloud infrastructure.
- 
- **Boundary:** Primary corporate offices and operational data centers/cloud tenancies supporting Megtech infrastructure.
- 

## 4. Context of the Organisation

### 4.1 Understanding the Organisation and its Context

Megtech determines internal and external factors relevant to its business purpose that affect its ability to achieve ISMS outcomes. These considerations include:

- The commercial and operational rationale for ISMS governance.
- 
- Customer, partner, and market security requirements.
- 
- Risk assessment findings, emerging cyber threats, system vulnerabilities, and privacy impact evaluations.
- 

### 4.2 Understanding the Needs and Expectations of Interested Parties

Megtech identifies and tracks relevant interested parties, including employees, shareholders, regulatory bodies, third-party suppliers, corporate clients, end users, and insurance providers. The ISMS maps and fulfills their security expectations, contractual obligations, and statutory/regulatory requirements.

### 4.3 Determining the Scope of the ISMS

The scope encompasses internal organizational units (including Product, Engineering, Infrastructure, and Corporate Support) and technological dependencies. Interfaces between internal environments and external integrations are formally managed within the system boundary.

### 4.4 ISMS Framework

Megtech establishes, implements, maintains, and continually improves an ISMS in conformity with ISO/IEC 27001:2022 to govern information risks, meet privacy requirements, and satisfy stakeholder obligations.

## 5. Leadership

### 5.1 Leadership and Commitment

Senior Management (operating via the ISMS Steering Committee) demonstrates commitment to the ISMS by:

- Integrating information security requirements into core engineering and business workflows.
- 
- Establishing security objectives aligned with strategic business goals.
- 
- Allocating financial, technical, and human resources to maintain and improve the ISMS.
- 
- Mandating internal audits, tracking remediation, and driving continuous improvement.

- 
- Conducting regular management reviews to evaluate ISMS health and compliance.
- 
- Prioritizing customer security and ensuring statutory compliance.
- 

## **5.2 Information Security Policy**

Megtech senior leadership maintains an Information Security and Privacy Policy that:

- Defines the framework for establishing and measuring security objectives.
- 
- Enforces the preservation of Confidentiality, Integrity, and Availability across all Megtech assets.
- 
- Mandates compliance with applicable laws, industry standards, and ISO/IEC 27001:2022 requirements.
- 
- Is published and communicated to all personnel, contractors, and relevant external parties.
- 

## **5.3 Organisational Roles, Responsibilities, and Authorities**

The ISMS Steering Committee oversees governance and implementation. Core membership comprises:

- Senior Executive Leadership
- 
- Cybersecurity and Data Privacy Lead
- 
- Head of Product
- 
- Technical Engineering Leads (Frontend, Backend, and Infrastructure)
- 
- IT Operations Representative
- 
- People / HR Operations Representative
- 

## **6. Planning**

### **6.1 Actions to Address Risks and Opportunities**

Risk management workflows identify, assess, and treat risks that could impact ISMS outcomes. Megtech applies structured risk criteria to ensure security investments target high-exposure areas and reinforce business continuity.

### **6.2 Information Security Objectives**

Megtech establishes measurable security and quality objectives across relevant functions. Objectives must be documented with assigned owners, resource allocations, completion milestones, and defined evaluation metrics.

### **6.3 Planning of Changes**

Modifications to the ISMS, organizational structures, or technology stacks must be planned to evaluate impact, preserve system integrity, ensure resource availability, and clearly delineate responsibilities.

## **7. Support**

### **7.1 Resources and Infrastructure**

Senior Management allocates appropriate infrastructure, software tooling, personnel, and network equipment to implement and sustain the ISMS. Monitoring and measurement tools must be calibrated, verified, and documented to ensure reliable evaluation metrics.

### **7.2 Competence**

Role-based competency profiles determine necessary security expertise. Training requirements must be assessed at least annually, with formal records maintained for all education, certifications, and internal training.

### **7.3 Awareness**

All personnel within the ISMS scope must undergo onboarding and recurring annual security awareness training. Training covers security policies, incident reporting, social engineering defense, and the impact of policy non-compliance.

### **7.4 Communication**

Megtech maintains internal and external communication protocols determining what security information must be communicated, when, to which audiences, and via which approved channels.

### **7.5 Documented Information**

All documentation, operational records, architecture diagrams, and control evidence required by ISO/IEC 27001:2022 must be formally created, approved, version-controlled, and safeguarded against unauthorized alteration.

## **8. Operation**

### **8.1 Operational Planning and Control**

Processes to satisfy information security criteria must be planned, implemented, monitored, and documented.

### **8.2 Product and Service Specifications**

Customer communication channels and security baseline disclosures are maintained across product documentation, contractual terms, and support mechanisms.

### **8.3 Design and Development Controls**

Engineering projects require formal planning, tracking, verification, and validation stages governed by designated Product and Technical Leads.

### **8.4 Control of Externally Provided Services**

Third-party vendors, suppliers, and cloud providers must undergo formal security capability assessments prior to onboarding, governed by recurring reviews and contractual security guarantees.

### **8.5 Production and Service Provision**

Production environments operate under controlled conditions. Software versions, configurations, and deployments must be uniquely identified, traceable, and subject to documented change management approvals.

## **8.6 Risk Assessment and Treatment**

- Formal risk assessments must be executed at least annually or upon significant organizational/architectural changes.
- 
- Risk Treatment Plans (RTP) must outline specific mitigation controls, assigned owners, resource requirements, and completion schedules.
- 

## **9. Performance Evaluation**

### **9.1 Monitoring, Measurement, and Analysis**

Megtech evaluates the operational performance and effectiveness of the ISMS using defined metrics, detailing what is measured, the methodology, the frequency, and the responsible analysis teams.

### **9.2 Internal Audit**

- Independent internal audits must be conducted at least annually.
- 
- Audits are governed by a defined audit charter and conducted by competent, objective personnel independent of the operational unit being audited.
- 
- Audit findings, nonconformities, and corrective actions must be tracked to complete resolution.
- 

### **9.3 Management Review**

The ISMS Steering Committee, chaired by the Managing Director/CEO, must convene at least annually to conduct a formal Management Review. The review covers audit findings, risk assessment updates, incident trends, resource adequacy, and continual improvement opportunities. Meeting minutes and actions must be formally recorded.

## **10. Improvement**

### **10.1 Nonconformity and Corrective Action**

When a security nonconformity occurs, the Cybersecurity team must contain the issue, evaluate root causes, deploy corrective actions, and verify remediation effectiveness to prevent recurrence. Documented evidence of all corrective actions must be retained.

### **10.2 Continual Improvement**

Megtech continually evaluates and enhances ISMS suitability, adequacy, and effectiveness by analyzing audit outcomes, incident metrics, and operational performance indicators.